

Virtual Hosts

A virtual host (vHost) is a feature that allows several websites to be hosted on a single server. This is an excellent solution if you have many websites and don't want to go through the time-consuming (and expensive) process of setting up a new web server for each one. Imagine having to set up a different webserver for a mobile and desktop version of the same page. There are two ways to configure virtual hosts:

- IP-based virtual hosting
- Name-based virtual hosting

IP-based Virtual Hosting

For this type, a host can have multiple network interfaces. Multiple IP addresses, or interface aliases, can be configured on each network interface of a host. The servers or virtual servers running on the host can bind to one or more IP addresses. This means that different servers can be addressed under different IP addresses on this host. From the client's point of view, the servers are independent of each other.

Name-based Virtual Hosting

The distinction for which domain the service was requested is made at the application level. For example, several domain names, such as `admin.inlanefreight.htb` and `backup.inlanefreight.htb`, can refer to the same IP. Internally on the server, these are separated and distinguished using different folders. Using this example, on a Linux server, the vHost `admin.inlanefreight.htb` could point to the folder `/var/www/admin`. For `backup.inlanefreight.htb` the folder name would then be adapted and could look something like `/var/www/backup`.

During our subdomain discovering activities, we have seen some subdomains having the same IP address that can either be virtual hosts or, in some cases, different servers sitting behind a proxy.

Imagine we have identified a web server at `192.168.10.10` during an internal pentest, and it shows a default website using the following command. Are there any virtual hosts present?

Name-based Virtual Hosting

```
dbcypn@htb[/htb]$ curl -s http://192.168.10.10

<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx!</title>
<style>
  body {
    width: 35em;
    margin: 0 auto;
    font-family: Tahoma, Verdana, Arial, sans-serif;
  }
</style>
</head>
<body>
<h1>Welcome to nginx!</h1>
<p>If you see this page, the nginx web server is successfully installed and
working. Further configuration is required.</p>

<p>For online documentation and support please refer to
<a href="http://nginx.org/">nginx.org</a>.<br/>
```

Integrated Terminal

```
[us-academy-1]-[10.10.14.11]-[htb-ac-819475@htb-ufxuijxfzt]-[~]  
[★]$  
<p><em>Thank you for using nginx.</em></p>  
</body>  
</html>
```

Let's make a **cURL** request sending a domain previously identified during the information gathering in the **HOST** header. We can do that like so:

Name-based Virtual Hosting

```
dbcypth0n@htb[/htb]$ curl -s http://192.168.10.10 -H "Host: randomtarget.com"  
  
<html>  
  <head>  
    <title>Welcome to randomtarget.com!</title>  
  </head>  
  <body>  
    <h1>Success! The randomtarget.com server block is working!</h1>  
  </body>  
</html>
```

Now we can automate this by using a dictionary file of possible vhost names (such as **/opt/useful/SecLists/Discovery/DNS/nameList.txt** on the Pwnbox) and examining the Content-Length header to look for any differences.

vHosts List

vHosts List

```
app  
blog  
dev-admin  
forum  
help  
m  
my  
shop  
some  
store  
support  
www
```

vHost Fuzzing

vHost Fuzzing

```
dbcypth0n@htb[/htb]$ cat ./vhosts | while read vhost;do echo "\n*****\nFUZZING: ${vhost}\n*****";curl -s  
  
*****  
FUZZING: app  
*****  
Content-Length: 612  
  
*****  
FUZZING: blog  
*****  
Content-Length: 612  
  
*****  
FUZZING: dev-admin  
*****  
Content-Length: 612
```

Integrated Terminal

```
*****
FUZZING: forum
*****
Content-Length: 612

*****
FUZZING: help
*****
Content-Length: 612

*****
FUZZING: m
*****
Content-Length: 612

*****
FUZZING: my
*****
Content-Length: 612

*****
FUZZING: shop
*****
Content-Length: 612

*****
FUZZING: some
*****
Content-Length: 195

*****
FUZZING: store
*****
Content-Length: 612

*****
FUZZING: support
*****
Content-Length: 612

*****
FUZZING: www
*****
Content-Length: 185
```

We have successfully identified a virtual host called `dev-admin`, which we can access using a `cURL` request.

vHost Fuzzing

```
dbcypth0n@htb[/htb]$ curl -s http://192.168.10.10 -H "Host: dev-admin.randomtarget.com"

<!DOCTYPE html>
<html>
<body>

<h1>Randomtarget.com Admin Website</h1>

<p>You shouldn't be here!</p>

</body>
</html>
```

Automating Virtual Hosts Discovery

We can use this manual approach for a small list of virtual hosts, but it will not be feasible if we have an extensive list. Using `ffuf`, we

Integrated Terminal

vHost Fuzzing	
MATCHER OPTIONS:	
-mc	Match HTTP status codes, or "all" for everything. (default: 200,204,301,302,307,401,403,
-ml	Match amount of lines in response
-mr	Match regexp
-ms	Match HTTP response size
-mw	Match amount of words in response
FILTER OPTIONS:	
-fc	Filter HTTP status codes from response. Comma separated list of codes and ranges
-fl	Filter by amount of lines in response. Comma separated list of line counts and ranges
-fr	Filter regexp
-fs	Filter HTTP response size. Comma separated list of sizes and ranges
-fw	Filter by amount of words in response. Comma separated list of word counts and ranges

```

vHost Fuzzing
dbccyph0n@htb[/htb]$ ffuf -w ./vhosts -u http://192.168.10.10 -H "HOST: FUZZ.randomtarget.com" -fs 612

  /'___\ /'___\ /'___\
/\ \_/\ /\ \_/\ __ __ /\ \_/\
\ \ ,__\ \ \ ,__\ \ \ \ \ \ \ ,__\
\ \ \_/\ \ \ \_/\ \ \ \ \ \ \ \_/\
 \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \
  \_/\ \_/\ \_/\ \_/\ \_/\

v1.1.0-git
-----
:: Method      : GET
:: URL         : http://192.168.10.10
:: Wordlist     : FUZZ: ./vhosts
:: Header      : Host: FUZZ.randomtarget.com
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405
:: Filter      : Response size: 612
-----
dev-admin      [Status: 200, Size: 120, Words: 7, Lines: 12]
www            [Status: 200, Size: 185, Words: 41, Lines: 9]
some           [Status: 200, Size: 195, Words: 41, Lines: 9]
:: Progress: [12/12] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::

```

- `-w`: Path to our wordlist
- `-u`: URL we want to fuzz
- `-H "HOST: FUZZ.randomtarget.com"`: This is the `HOST` Header, and the word `FUZZ` will be used as the fuzzing point.
- `-fs 612`: Filter responses with a size of 612, default response size in this case.

⚠ Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

● UDP 1337 ● TCP 443

DOWNLOAD VPN CONNECTION FILE



Full Screen

Terminate

Reset

Life Left: 24m

+

Connected to htb-ufxuijxfzt:1 (htb-ac-819475)

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: 10.129.164.245



Life Left: 117 minutes



Cheat Sheet



Download VPN
Connection File

vHosts needed for these questions:

- www.inlanefreight.htb

+1

Enumerate the target and find a vHost that contains flag No. 1. Submit the flag value as your answer (in the format HTB{DATA}).

Submit your answer here...

Integrated Terminal

[Submit](#)

+1  Enumerate the target and find a vHost that contains flag No. 2. Submit the flag value as your answer (in the format HTB{DATA}).

[Submit](#)

+1  Enumerate the target and find a vHost that contains flag No. 3. Submit the flag value as your answer (in the format HTB{DATA}).

[Submit](#)

+1  Enumerate the target and find a vHost that contains flag No. 4. Submit the flag value as your answer (in the format HTB{DATA}).

[Submit](#)

+1  Find the specific vHost that starts with the letter "d" and submit the flag value as your answer (in the format HTB{DATA}).

[Submit](#)[← Previous](#)[Next →](#)[📄 Cheat Sheet](#)[? Go to Questions](#)

Table of Contents

Information Gathering



Passive Information Gathering

 WHOIS



 DNS



Passive Subdomain Enumeration



Passive Infrastructure Identification



Integrated Terminal

Active Infrastructure Identification

Active Subdomain Enumeration

Virtual Hosts

Crawling

Putting it all Together

Information Gathering - Web - Skills Assessment

My Workstation



Interact

Terminate

Reset

Life Left: 24m

